QUESTION #01

Difference Between TCP and UDP:

TCP (Transmission Control Protocol) is connection-oriented, meaning it establishes a stable connection between sender and receiver before data transfer. It ensures reliable, ordered, and error-checked delivery of data.

UDP (User Datagram Protocol) is connectionless, meaning it sends data without establishing a connection. It is faster but does not guarantee delivery, order, or error-checking.

Real-World Scenarios

TCP:

1. Web browsing (HTTP/HTTPS) – Ensures all webpage data loads fully and correctly.
2. Email (SMTP, IMAP) – Guarantees reliable delivery of email messages.

UDP:

1. Live video streaming – Prioritizes speed over reliability; a few missed frames are acceptable.
2. Online gaming – Fast data transmission is critical; occasional packet loss is tolerable.

Best Protocol for Secure File Transfers

File transfers require complete, accurate data delivery. TCP ensures data integrity, order, and reliability—essential for secure transfers (e.g., **SFTP**, **FTPS**), whereas UDP may result in data loss or corruption.

QUESTION #02

ARP Spoofing

ARP spoofing (Address Resolution Protocol spoofing) is a type of cyberattack where a malicious actor sends fake ARP messages over a local network. The goal is to associate their MAC address with the IP address of another device (like a router or another user) to intercept, modify, or block data intended for that IP.

1. In a LAN, devices use ARP to map IP addresses to MAC addresses.

2. An attacker sends forged ARP replies, tricking devices into believing the attacker's MAC address corresponds to a trusted IP (e.g., the gateway).
3. As a result, data meant for the legitimate IP is sent to the attacker instead.
4. The attacker can then:
    - **Monitor** traffic (Man-in-the-Middle),
    - **Alter** data in transit,
    - **Steal credentials**, or
    - **Disconnect devices**.

Potential Impact:

- Data interception (including passwords and sensitive info)
- Session hijacking
- Denial of Service (DoS)
- Network instability
- Loss of confidentiality and integrity

Detection:

- **Unusual ARP table entries** (e.g., multiple IPs pointing to one MAC)
- **Network scanning tools** like:
    - arpwatch
    - XArp
    - Wireshark (to detect duplicate IPs or conflicting MACs)
- **Traffic analysis** showing abnormal routing

Prevention:

1. **Static ARP entries** – Manually define trusted IP-MAC mappings.
2. **Packet filtering** – Configure switches to block spoofed packets.
3. **Use of secure protocols** – Prefer encrypted communication (HTTPS, SSH).
4. **Enable Dynamic ARP Inspection (DAI)** – On managed switches to validate ARP packets.
5. **Network segmentation and VLANs** – Reduce attack surface.

QUESTION #03

Realistic Scenario Where IDS/IPS Might Fail

A company uses an IDS/IPS to monitor network traffic. An attacker performs a **slow, low-and-slow data exfiltration attack** by sending **encrypted packets** over **HTTPS** from an internal compromised machine to an external server. The IDS/IPS, which relies on pattern matching and does not decrypt HTTPS traffic, **fails to detect the slow, hidden exfiltration**.

FAILURE:

- The data was **encrypted**, so payload inspection was ineffective.
- The attack was **very gradual**, avoiding traffic volume spikes.
- The traffic used **legitimate protocols and ports** (e.g., port 443).

As a Cybersecurity Analyst, I Would:

1. Implement SSL/TLS Interception (Where Legally and Ethically Permissible):

- Use **Web Proxy with SSL inspection** (e.g., **Zscaler**, **FortiGate**) to inspect encrypted traffic.

2. Deploy Advanced Endpoint Detection and Response (EDR):

- Tools like **CrowdStrike**, **Microsoft Defender for Endpoint**, or **SentinelOne** monitor for suspicious process behavior (e.g., PowerShell accessing unusual IPs).

3. Monitor for Anomalous Behavior:

- Set up **UEBA** (User and Entity Behavior Analytics) with **SIEM tools** like:
  - **Splunk**
  - **IBM QRadar**
  - **Microsoft Sentinel**
- Look for deviations in user activity like accessing files outside work hours or communicating with unknown IPs.

4. Correlate Logs Across Systems:

- Correlate network traffic logs with endpoint logs and DNS queries.
- Use tools like **ELK Stack** or **Graylog** for custom dashboards and alerts.

5. Hunt Proactively:

- Perform **Threat Hunting** using **YARA rules**, **Sigma rules**, and IOC (Indicators of Compromise) feeds.
- Review **NetFlow data** for persistent, small data transfers to unknown destinations.

Summary:
IDS/IPS can miss encrypted, slow, or obfuscated attacks. To catch them, combine **behavior-based analytics**, **EDR tools**, **log correlation**, and **active hunting strategies**.

QUESTION #04

The **OSI model** was the hardest to understand because it's abstract and theoretical—especially differentiating between similar layers like the **Session**, **Presentation**, and **Application** layers. Understanding how data flows and transforms at each layer can feel confusing without clear, real-world context.

Plan to Improve:

- **Use visual diagrams** to map real protocols (e.g., HTTP, SSL, TCP) to each layer.
- Watch **interactive video tutorials** or simulations (like Wireshark captures) to see how packets behave at each layer.
- Practice explaining each layer's function using analogies or role-play scenarios (like postal mail delivery).
- Use **flashcards or quizzes** (e.g., on Cisco NetAcad or Quizlet) to reinforce concepts.

QUESTION #05

1. Application Layer (OSI 7,6,5) → Application Layer (TCP/IP)

- **OSI Layers:** Application, Presentation, Session
- **TCP/IP Layer:** Application
- **Example: HTTP** (used for web browsing)

2. Transport Layer (OSI 4) → Transport Layer (TCP/IP)

- **OSI Layer:** Transport
- **TCP/IP Layer:** Transport
- **Example: TCP** (ensures reliable delivery)

3. Network Layer (OSI 3) → Internet Layer (TCP/IP)

- **OSI Layer:** Network

- **TCP/IP Layer:** Internet
- **Example: IP** (routes packets between devices)

4. Data Link + Physical Layers (OSI 2,1) → Network Access Layer (TCP/IP)

- **OSI Layers:** Data Link, Physical
- **TCP/IP Layer:** Network Access
- **Example: Ethernet** (defines frame structure on LAN)